

Informe Técnico de Pentest

Vulnerable Accounting System

1. Resumen Ejecutivo

Se realizó un pentest completo sobre el sistema vulnerable de contabilidad, identificando 45 vulnerabilidades distribuidas en múltiples categorías de seguridad. El análisis incluyó reconocimiento, enumeración, análisis automatizado y explotación controlada de vulnerabilidades.

1.1 Distribución por Severidad

- Críticas (Critical): 12 vulnerabilidades (CVSS 9.0-10.0)
- Altas (High): 18 vulnerabilidades (CVSS 7.0-8.9)
- Medianas (Medium): 10 vulnerabilidades (CVSS 4.0-6.9)
- Bajas (Low): 5 vulnerabilidades (CVSS 0.1-3.9)

1.2 Categorías Principales

- SQL Injection (múltiples endpoints)
- Ejecución Remota de Código (RCE)
- Broken Authentication & Authorization
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Insecure Direct Object Reference (IDOR)
- Security Misconfiguration
- Information Disclosure

2. Metodología

2.1 Fase 1: Reconocimiento y Enumeración

2.1.1 Escaneo de Puertos

Herramienta: Nmap / Test-NetConnection (PowerShell)

Resultados:

- Puerto 80: Nginx (Reverse Proxy) - ABIERTO
- Puerto 8000: Backend Laravel API - ABIERTO
- Puerto 3000: Frontend Vue.js - ABIERTO
- Puerto 3306: MySQL Database - ABIERTO
- Puerto 6379: Redis - ABIERTO
- Puerto 8080: phpMyAdmin - ABIERTO
- Puerto 8025: MailHog - ABIERTO

Evidencia: evidencias/puertos_activos.txt

2.1.2 Enumeración de Endpoints

Herramienta: Análisis de código fuente + Pruebas manuales

Endpoints Identificados:

API Routes (/api):

- /api/auth/* - Autenticación (6 endpoints)
- /api/dashboard/* - Dashboard (1 endpoint)
- /api/modules/* - Módulos contables (4 endpoints)
- /api/admin/* - Panel administrativo (9 endpoints)
- /api/debug/* - Endpoints de debug (7 endpoints)
- /api/upload - Carga de archivos
- /api/contact - Formulario de contacto

Web Routes:

- / - Información del sistema
- /phpinfo - PHP Info
- /env - Variables de entorno
- /db-test - Test de conexión DB
- /logs - Visor de logs
- /browse - Navegador de archivos
- /config - Dump de configuración
-

```
/artisan/{command} - Ejecución de comandos
Artisan
/session - Manipulación de sesiones
/status - Estado del servidor
```

Evidencia: evidencias/endpoints_test.txt

2.1.3 Análisis de Headers HTTP

Hallazgos:

- CORS: Configuración permisiva (Access-Control-Allow-Origin: *)
- Server: Apache/2.4.x (información expuesta)
- X-Powered-By: PHP/8.x (información expuesta)
- Debug Mode: Activado en producción

Evidencia: evidencias/headers_backend.txt

2.2 Fase 2: Análisis de Vulnerabilidades

2.2.1 Análisis Estático de Código

Herramienta: Revisión manual de código fuente

Vulnerabilidades Identificadas:

- 45 vulnerabilidades documentadas en análisis estático
- Referencias: report_final_v2.md

2.2.2 Análisis de Configuración

Hallazgos:

- APP_DEBUG=true en producción
 - Credenciales de base de datos expuestas
 - Redis sin autenticación
 - CORS configurado para aceptar cualquier origen
-

2.3 Fase 3: Explotación Controlada

2.3.1 SQL Injection

VULN-001: SQL Injection en Login

- Endpoint: POST /api/auth/login
- CVSS: 9.8 (Critical)
- Payload: admin' OR '1'='1' --
- Impacto: Bypass de autenticación, acceso no autorizado

Evidencia: evidencias/exploit_sqli_login_pentest.txt

Request:

```
POST /api/auth/login HTTP/1.1
Host: localhost:8000
Content-Type: application/json

{
  "username": "admin' OR '1'='1' --",
  "password": "test"
}
```

Response:

```
{
  "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2Vybm91dCI6ImFkbWlnIiwiaWF0IjoxNjU0OTU0MDA0LCJyb2UiOiJhZG9pbnQifQ",
  "user": {
    "id": 1,
    "username": "admin",
    "role": "admin"
  }
}
```

VULN-002: SQL Injection en Debug

Endpoint: POST /api/debug/sql-execute

CVSS: 9.8 (Critical)

Payload: SELECT * FROM users UNION SELECT 1,2,3,4,5,6,7,8,9,10

Impacto: Extracción completa de base de datos

Evidencia: evidencias/exploit_sqli_debug.txt

- VULN-003: SQL Injection en Admin
 - Endpoint: POST /api/admin/sql
 - CVSS: 9.8 (Critical)
 - Impacto: Ejecución de comandos SQL arbitrarios
 - Evidencia: evidencias/exploit_sqli_admin.txt
-
- 2.3.2 Ejecución Remota de Código (RCE)
 - VULN-004: RCE vía Command Injection
 - Endpoint: POST /api/debug/execute-command
 - CVSS: 10.0 (Critical)
 - Payload: whoami; cat /etc/passwd
 - Impacto: Control total del servidor
 - Evidencia: evidencias/exploit_rce_debug_pentest.txt

Request:

```
POST /api/debug/execute-command HTTP/1.1
Host: localhost:8000
Content-Type: application/json

{
  "command": "whoami"
}
```

Response:

```
{
  "output": "www-data",
  "exit_code": 0
}
```

VULN-005: RCE vía PHP eval()

- Endpoint: POST /api/debug/php-execute
- CVSS: 10.0 (Critical)
- Payload: system('cat /etc/passwd');
- Impacto: Ejecución de código PHP arbitrario
- Evidencia: evidencias/exploit_rce_php.txt

VULN-006: RCE vía Admin Execute

- Endpoint: POST /api/admin/execute
- CVSS: 10.0 (Critical)
- Impacto: Ejecución de comandos del sistema
- Evidencia: evidencias/exploit_rce_admin.txt

2.3.3 Broken Authentication

VULN-007: Admin Bypass Token

- Endpoint: POST /api/auth/admin-login
- CVSS: 9.1 (Critical)
- Token Hardcodeado: admin_bypass_token_123
- Impacto: Acceso administrativo sin credenciales
- Evidencia: evidencias/exploit_admin_bypass_pentest.txt

Request:

```
POST /api/auth/admin-login HTTP/1.1
Host: localhost:8000
Content-Type: application/json

{
  "token": "admin_bypass_token_123"
}
```

Response:

```
{
  "token": "admin_token_...",
  "user": {
    "id": 1,
    "username": "admin",
    "role": "admin"
  }
}
```

```
}  
}
```

VULN-008: Credenciales por Defecto

- Endpoint: POST /api/auth/login
 - CVSS: 7.5 (High)
 - Credenciales: admin:admin123
 - Impacto: Acceso no autorizado
- Evidencia: evidencias/test_credenciales_default.txt

2.3.4 Insecure Direct Object Reference (IDOR)

VULN-009: IDOR en Actualización de Roles

- Endpoint: PUT /api/admin/users/{userId}/role
- CVSS: 8.1 (High)
 - Impacto: Escalación de privilegios
 - Evidencia: evidencias/exploit_idor_user.txt

VULN-010: IDOR en Acceso a Datos

- Endpoint: GET /api/modules/{module}/data?userId=1
 - CVSS: 7.5 (High)
 - Impacto: Acceso a datos de otros usuarios
- Evidencia: evidencias/exploit_idor_data.txt

2.3.5 Cross-Site Scripting (XSS)

VULN-011: XSS Reflejado

- Endpoint: POST /api/contact
- CVSS: 6.1 (Medium)
 - Payload: <script>alert('XSS')</script>
 - Impacto: Robo de sesiones, phishing
 - Evidencia: evidencias/exploit_xss_reflected.txt

VULN-012: XSS Almacenado

- Endpoint: POST /api/modules/{module}/entries
 - CVSS: 6.1 (Medium)
 - Payload:
 - Impacto: Ejecución persistente de JavaScript
- Evidencia: evidencias/exploit_xss_stored.txt

2.3.6 Cross-Site Request Forgery (CSRF)

VULN-013: CSRF en Cambio de Rol

- Endpoint: PUT /api/admin/users/{userId}/role
 - CVSS: 6.5 (Medium)
 - Impacto: Escalación de privilegios sin consentimiento
- Evidencia: evidencias/exploit_csrf_role.txt

VULN-014: CSRF en Eliminación

- Endpoint: DELETE /api/admin/users/{userId}
 - CVSS: 6.5 (Medium)
 - Impacto: Eliminación no autorizada de usuarios
- Evidencia: evidencias/exploit_csrf_delete.txt

2.3.7 Path Traversal

VULN-015: Path Traversal en Lectura de Archivos

- Endpoint: POST /api/debug/read-file
- CVSS: 7.5 (High)
- Payload: ../../../../etc/passwd
- Impacto: Lectura de archivos del sistema
- Evidencia: evidencias/exploit_path_traversal.txt

- VULN-016: Path Traversal en File Browser
- Endpoint: GET /browse?path=../../../../
- CVSS: 7.5 (High)
- Impacto: Navegación fuera del directorio permitido
- Evidencia: evidencias/exploit_file_browser.txt

- 2.3.8 Information Disclosure
- VULN-017: Exposición de Variables de Entorno

- Endpoint: GET /env
- CVSS: 7.5 (High)
 - Impacto: Exposición de credenciales y configuración
 - Evidencia: evidencias/info_sistema.txt

VULN-018: Exposición de Credenciales de DB

- Endpoint: GET /db-test
- CVSS: 7.5 (High)
- Impacto: Credenciales de base de datos expuestas
- Evidencia: evidencias/test_root_endpoint.txt

VULN-019: PHP Info Expuesto

- Endpoint: GET /phpinfo
- CVSS: 5.3 (Medium)
 - Impacto: Información detallada del servidor
 - Evidencia: evidencias/headers_backend.txt

VULN-020: Configuración Expuesta

- Endpoint: GET /config
- CVSS: 7.5 (High)
- Impacto: Toda la configuración de Laravel expuesta
- Evidencia: evidencias/info_sistema.txt

3. Clasificación de Vulnerabilidades

3.1 Críticas (Critical) - CVSS 9.0-10.0

ID	Vulnerabilidad	CVSS	Endpoint
VULN-004	RCE vía Command Injection 10.0	10.0	/api/debug/execute-command
VULN-005	RCE vía PHP eval()	10.0	/api/debug/php-execute
VULN-006	RCE vía Admin Execute	10.0	/api/admin/execute
VULN-001	SQL Injection en Login	9.8	/api/auth/login
VULN-002	SQL Injection en Debug	9.8	/api/debug/sql-execute
VULN-003	SQL Injection en Admin	9.8	/api/admin/sql
VULN-007	Admin Bypass Token	9.1	/api/auth/admin-login

3.2 Altas (High) - CVSS 7.0-8.9

ID	Vulnerabilidad	CVSS	Endpoint
VULN-008	Credenciales por Defecto	7.5	/api/auth/login
VULN-015	Path Traversal (Read File)	7.5	/api/debug/read-file
VULN-016	Path Traversal (File Browser)	7.5	/browse
VULN-017	Exposición de Variables de Entorno 7.5	7.5	/env
VULN-018	Exposición de Credenciales DB	7.5	/db-test
VULN-020	Configuración Expuesta	7.5	/config
VULN-009	IDOR en Actualización de Roles	8.1	/api/admin/users/{id}/role
VULN-010	IDOR en Acceso a Datos	7.5	/api/modules/{module}/data

3.3 Medianas (Medium) - CVSS 4.0-6.9

ID	Vulnerabilidad	CVSS	Endpoint
VULN-011	XSS Reflejado	6.1	/api/contact

VULN-012 XSS Almacenado6.1/api/modules/{module}/entries
VULN-013 CSRF en Cambio de/api/admin/users/{id}/role
Rol 6.5
VULN-014 CSRF en /api/admin/users/{id}
Eliminación 6.5
VULN-019 PHP Info Expuesto /phpinfo
5.3
3.4 Bajas (Low) - CVSS 0.1-3.9

- Información de versión en headers
- Debug mode activado
- Server tokens expuestos

4. Recomendaciones Prioritarias

4.1 Inmediatas (Críticas)

1. Deshabilitar endpoints de debug en producción
2. Implementar autenticación en todos los endpoints
3. Eliminar token hardcodeado de admin bypass
4. Sanitizar todas las entradas SQL (usar prepared statements)
5. Deshabilitar eval() y funciones peligrosas de PHP

4.2 Corto Plazo (Altas)

1. Implementar CSRF tokens
2. Validar y sanitizar todas las entradas
3. Ocultar información del servidor
4. Configurar CORS correctamente
5. Implementar rate limiting

4.3 Mediano Plazo (Medianas)

1. Implementar Content Security Policy (CSP)
 2. Validar y sanitizar salidas (prevenir XSS)
 3. Implementar logging y monitoreo
 4. Revisar y actualizar dependencias
-

5. Conclusiones

El sistema presenta múltiples vulnerabilidades críticas que permiten:

- Control total del servidor (RCE)
- Acceso no autorizado (SQL Injection, Bypass)
- Exposición de datos sensibles (Information Disclosure)
- Manipulación de datos (IDOR, CSRF)

Se recomienda remediación inmediata de las vulnerabilidades críticas antes de poner el sistema en producción.

Fin del Reporte

•